

# Research Proposal Presentation

Hello. I am Stephanie. My project is called: *"Identity and Access Governance in Azure: Experimental Evaluation of Entra ID IAM Mechanisms to Secure API Access in a Vulnerable Cloud Environment Using the Zero Trust Model."*

## Context and Justification

Today, the massive shift to the cloud is disrupting traditional security models. As Kodakandla (2024) and Shore (2021) explain, identities have become the main target of cyberattacks, especially through exposed API access.

The Zero Trust model, defined by NIST, requires never trusting any user or system by default and checking every access continuously. Chandramouli and Butcher (2023) show it is becoming an essential standard.

Microsoft Azure, through Entra ID, provides a full set of IAM mechanisms designed to limit privileges, segment access, and improve auditability. But as Bush and Mashatan point out, using these tools is still complex, and their real impact on API security is not well documented.

Finally, Bobbert, Scheerder, Levine, and Tucker note that there are very few experimental studies showing the true effect of these controls in vulnerable environments.

The goal is to test these IAM mechanisms in Azure on a vulnerable app like Broken Crystal, to measure how effective they really are at securing API access and to produce empirical data that the literature still lacks.

## Significance, Contribution and Research Problem

As shown on the slide, the research question and the main hypothesis define the core focus of this project.

The research question is:

"To what extent do the IAM mechanisms offered by Microsoft Entra ID improve the security, traceability, and governance of API access in a vulnerable cloud environment when evaluated under the Zero Trust model?"

The main hypothesis is that combining RBAC, PIM, MFA, and Conditional Access not only blocks intrusions more effectively but also makes abuse attempts easier to detect and trace. This is often a weak point in hybrid cloud systems.

This work aims to fill several important gaps.

First, most publications remain theoretical and lack experimental evidence of how these configurations perform during simulated attacks.

Second, the issue of operational trade-offs is rarely discussed-for example, how adding multiple controls affects legitimate access and what compromises organisations have to accept.

The project will also examine the real granularity of IAM permissions applied to APIs, which is often described as a blind spot.

Finally, it will produce detailed and reproducible data to support future implementations.

To achieve these goals, the project will combine:

- A technical foundation to set up and compare IAM controls
- A theoretical framework based on Zero Trust principles
- A controlled experimental environment to simulate attacks
- A vulnerable application, Broken Crystal, that reflects common API weaknesses

In short, this project is not just about describing controls. It will measure their actual effectiveness, limitations, and operational impacts to help reduce the uncertainties that still hold back Zero Trust adoption.

## Key Literature

Microsoft Azure offers powerful IAM mechanisms that reflect the Zero Trust approach described by NIST in publication SP 800-207.

But their real effectiveness and adoption are still uneven.

For example, the advanced granularity of RBAC is seen as a strong point, as Rose and Shore showed in 2021. Yet Bush and Mashatan (2022) explain that it requires constant organizational discipline, which is often hard to keep over time.

PIM reduces the risk of permanent privileges, but it is seen as heavy and restrictive, which slows down its use. Levine and Tucker noted this in 2023.

Multifactor authentication is an important pillar of Zero Trust, but its impact varies depending on the subscription level and user acceptance. Michael (2022) raised these limits.

Another critical point is API security. Teerakanok and Uehara (2021) stressed that machine-to-machine access remains a major weak spot. The complexity of OAuth2, the token lifetime, and the low granularity of controls increase the risk.

Automatic key rotation is rarely applied, creating tension between security and workflow stability.

Finally, most studies stay at a conceptual level, without concrete tests or reproducible experiments. This was observed by Levine, Tucker, Teerakanok, and Uehara.

Next, the literature highlights several practical limits and important questions.

Applying Zero Trust principles like least privilege and continuous verification often faces challenges. Michael and Bush (2022) mention cognitive overload, increased complexity, and operational slowdowns.

For APIs, Teerakanok and Uehara explain that frequent token rotation and access reviews can disrupt business processes. These constraints often lead to partial or inconsistent configurations, creating persistent risks, as Levine and Tucker (2023) observed.

Another issue is the lack of experimental studies. Many recommendations assume ideal conditions-skilled teams, a strong security culture, and full user support-which are rarely present in real environments.

Even Microsoft's own documentation admits some limits: Conditional Access is not always compatible with all APIs, and reducing token lifetimes often requires redesigning applications, especially those using OAuth2, as Shore and Teerakanok explain.

RBAC audits also remain limited without regular reviews (Bush and Mashatan), and most publications lack independent validation (Michael, 2022).

This raises key questions:

- Does combining RBAC, PIM, and Conditional Access really secure APIs?
- Is the current level of control granular enough?
- What trade-offs are acceptable without compromising Zero Trust principles?

In conclusion, the literature shows a paradox: IAM is considered a core pillar of cloud security, but its implementation is still mostly theoretical and under-evaluated, especially for vulnerable APIs.

This project aims to fill this gap by testing these configurations in practice and producing clear, reproducible evidence.

## **Aims and Objectives**

Objectives are organized around eight main areas.

Configure in Azure the essential IAM mechanisms, such as RBAC, PIM, MFA, and Conditional Access, following the NIST SP 800-207 framework, as described by Rose, Shore, and Bush.

Create a controlled experimental environment with the vulnerable application Broken Crystal to simulate realistic attacks, as recommended by Michael and Levine.

Design and run different scenarios to assess the impact of IAM controls on varied user profiles, in line with Levine and Bush.

Carry out controlled attacks, such as privilege escalation and consent phishing, as described by Teerakanok and Shore.

Measure how well the configurations align with Zero Trust principles: least privilege, continuous verification, and auditability, according to Rose and Michael.

Analyze the identity lifecycle by evaluating the management and revocation of privileges, as shown by Shore and Levine.

Identify technical and organizational limits related to the tension between security and productivity, as noted by Bush and Michael.

Propose practical recommendations to strengthen API security with Entra ID, based on the work of Shore and Levine.

## **Methodology and Research Design**

My methodology combines several complementary dimensions, aiming to respond to the calls from Michael et al. (2022) and Levine & Tucker (2023) by offering a rigorous and reproducible experiment to concretely assess the effectiveness of Entra ID IAM mechanisms for securing vulnerable API access.

First, the general approach:

- It is **exploratory**, because API security with Azure Entra ID is still not deeply studied. Michael and Levine highlight this gap.
- It is **experimental**, since I will directly configure IAM settings to observe their real effects.
- It is **evaluative**, with the goal of measuring the effectiveness of each mechanism precisely.

The experimental design is mixed:

- I will rely on the case study of **Broken Crystal**, a known vulnerable application deployed in Azure.
- The aim is to create **reproducible configurations** that can be tested and compared.
- The scenarios will include different types of users to cover real risks comprehensively.
- This **comparative approach** will show whether each IAM control is effective on its own and in combination with others.

Finally, data collection will be diverse:

- I will use **direct observation** of access attempts, analysis of Azure logs (such as Activity Logs), and screenshots and exports from dashboards.
- This documentation will be enriched with the analysis of scientific literature and official Microsoft guides, as Bush and Mashatan recommend.

For the data types, I will collect two main categories of information.

- **Primary data** from the experiments, for example the number of blocked attempts, revocation times, or detailed logs.
- **Secondary data**, such as Microsoft's technical documentation and key scientific publications.

This data will be both **quantitative**, with clear performance indicators, and **qualitative**, to describe behaviors and gaps observed during the tests.

The analytical process will rely on several methods:

- I will systematically cross-check the applied configurations, the simulated scenarios, and the generated logs-this is **triangulation**.
- I will also use a **Zero Trust analysis grid**, assessing four principles: least privilege, continuous verification, auditability, and segmentation, as described by Rose and Shore.
- Finally, I will compare the **isolated and combined effects** of the IAM controls to measure their overall effectiveness.

To ensure quality and reliability, several measures will be put in place:

- I will do **iterative cross-checking** of sources, verifying consistency between logs, exports, and my observations.
- Quantitative and qualitative data will be analyzed together to limit bias.
- All information will be **timestamped, versioned, and stored in secure environments**, such as Azure Storage and a private Git repository.

These measures are intended to guarantee the **transparency and credibility** of the results, in line with the standards expected in applied cybersecurity research.

## Research Questions and Analytical Angles

My project focuses on ten key areas to assess how Entra ID can secure API access in Azure.

- Access control and privilege management.

I'll look at how least privilege principles are applied in practice with RBAC and PIM, and whether access reviews actually prevent excessive permissions over time.

- Traceability and auditability.

I'll evaluate if the logs are complete and reliable enough to detect suspicious activity and support incident investigations, especially when integrated with Sentinel and Defender.

- Contextual access.

This means testing Conditional Access policies to see how effectively they block risky logins based on factors like location or device compliance.

- The identity lifecycle.

I'll check how well Entra ID manages account creation, modification, and deletion, and whether these processes meet GDPR requirements for accountability and data minimization.

- The balance between security and usability.

I'll measure the impact of strict controls-like strong MFA or PIM activation-on user experience and identify where trade-offs are needed to keep operations smooth without reducing security.

Here are additional areas.

- Attack surface reduction.

I'll compare an unsecured Azure environment with one protected by strict IAM configurations to see how effectively they limit exposure and control access per role.

- Compliance with the Zero Trust model.

The idea is to verify whether the setup meets key principles like continuous verification and least privilege, and to identify any practical constraints such as licensing requirements.

- IAM incident response.

I'll simulate targeted attacks-like token reuse or privilege escalation-and measure how well the system reacts, including alerts and blocks, compared to an unprotected baseline.

- Interoperability across workloads.

I'll test how IAM policies apply to different Azure resources-APIs, virtual machines, Logic Apps-to see where limitations or adjustments are needed, especially for securing Broken Crystal's vulnerable APIs.

- Operational maturity and complexity.

I'll evaluate how challenging it is to manage all these tools together, and whether organisations can realistically adopt these practices without excessive overhead.

## **Ethical Considerations, Scope and Deliverables**

This project is designed within a strictly experimental and ethical framework.

All configurations and scenarios will be carried out in a fully isolated and controlled Azure environment, with no real or sensitive data.

The identities and accounts used will be entirely fictional, which ensures that no user consent is required.

The project fully complies with academic ethical standards and best practices in cybersecurity research.

The scope is precisely defined:

The included elements cover the advanced configuration of IAM mechanisms: RBAC, PIM, MFA, Conditional Access, and Access Reviews.

The tests will focus specifically on securing API access exposed by Broken Crystal and evaluating their strength according to Zero Trust principles.

I will simulate incidents such as privilege escalation or token reuse and will fully document the results and recommendations.

In contrast, some areas are intentionally excluded:

There will be no tests in production environments, no classic network attacks like DDoS or SQL injections, and no analysis beyond the scope of Entra ID IAM.

Finally, several concrete deliverables will be produced:

I will provide detailed configurations and an isolated Azure tenant, complete experiment reports, exhaustive logs from Azure, Defender, and Sentinel, and reproducible methodological guides.

These materials will validate the approach and offer clear, transferable recommendations.

## **Timeline**

The project spans thirty weeks: first, research preparation, ethical approval, and preliminary review; then refining the literature review and designing scenarios; setting up Azure and configuring IAM; conducting experiments and collecting data; analyzing results; finally, writing the report and preparing the presentation.

## **Alignment to CyBOK and BCS Standards**

My project fits into five major Knowledge Areas of the CyBOK.

**Authentication, Authorisation, and Accountability** is the core of the approach: configuring and evaluating controls such as RBAC, PIM, MFA, and Conditional Access, directly linked to the essential mechanisms described by Gollmann in the CyBOK.

**Cloud Security** focuses on securing Azure environments and reducing the attack surface of APIs, a key point in cloud architectures, as the CyBOK highlights.

**Risk Management and Governance.**

The experimental approach, combining Zero Trust with proactive risk management, follows the recommendations of Burnap and NIST SP 800-207.

**Security Operations and Incident Management.**

Attack simulations and IAM incident response, such as token reuse and privilege escalation, clearly illustrate this dimension.

**Privacy and Online Rights.**

Managing access rights and ensuring GDPR compliance help guarantee confidentiality and the minimisation of privileges.

Regarding BCS standards:

It produces a concrete artefact: a full Azure tenant with controlled attack scenarios and reproducible configurations.

It offers an original contribution: applied experimentation of several combined IAM mechanisms on vulnerable APIs.

The methodology uses a systematic and critical approach: mapping personas, defining performance indicators, and analyzing limitations.

The ethical aspect is ensured by using only fictional data and an isolated environment, in line with BCS recommendations.

## **Risk Assessment**

The project has undergone a thorough risk assessment across three main categories.

Technical risks include the complexity of setting up Azure, deploying Broken Crystal, and configuring advanced IAM policies. To mitigate this, a feasibility test will be conducted early, supported by planning and automated scripts. Potential data loss will be prevented through regular Git backups, strict documentation, and integrity checks. Quota or license limitations will be anticipated by verifying prerequisites. Finally, possible Azure service outages will be managed with time buffers and snapshots to restore the environment quickly.

Methodological risks involve the learning curve for advanced IAM configurations, since not all aspects are covered in the programme. This will be addressed by dedicating time to Microsoft Learn training, consulting official documentation, and seeking expert advice. The limited academic literature will be balanced by early research, grey literature, and exploring related topics like API governance and Zero Trust. The complexity of scenarios and metric collection could cause delays, so scenarios will be prioritised and all steps carefully documented.

Organisational risks mainly concern schedule delays. A phased timeline, regular progress monitoring, and close communication with the supervisor will help maintain control. There is also a risk of unintentionally disclosing sensitive information; this will be prevented by systematic anonymisation, clear disclaimers about the experimental scope, and prior validation of deliverables.

These risks will be monitored continuously, with additional measures ready if new issues arise.

## **Conclusion**

In summary, this project experimentally evaluates Azure IAM mechanisms to secure APIs in a vulnerable environment. It measures their effectiveness, highlights limitations, and adds evidence to support Zero Trust practices in real scenarios.

Thank you for your attention.

The reference list is shown below.

## References

BCS - The Chartered Institute for IT, 2019. BCS Project Requirements. BCS - The Chartered Institute for IT. Available at: <https://www.bcs.org> [Accessed 15 June 2025].

Bobbert, Y. and Scheerder, J., 2022. Zero Trust Validation: from Practice to Theory: An empirical research project to improve Zero Trust implementations. 2022 IEEE 29th Annual Software Technology Conference (STC), pp.93-104. Available at: <https://ieeexplore.ieee.org/document/9951014> [Accessed 10 June 2025].

Bush, N. and Mashatan, A., 2022. From Zero to One Hundred: Demystifying zero trust and its implications on enterprise people, process, and technology. ACM Digital Library. Available at: <https://dl.acm.org/doi/abs/10.1145/3561799> [Accessed 9 June 2025].

Chandramouli, R. and Butcher, Z., 2023. A Zero Trust Architecture Model for Access Control in Cloud-Native Applications in Multi-Location Environments. NIST Special Publication 800-207A. Available at: <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-207A.pdf> [Accessed 8 June 2025].

European Union, 2016. Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data (General Data Protection Regulation). Official Journal of the European Union, L119, pp.1-88. Available at: <https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX%3A32016R0679> [Accessed 14 June 2025].

Kodakandla, N., 2024. Securing Cloud-Native Infrastructure with Zero Trust Architecture. ResearchGate. Available at: [https://www.researchgate.net/profile/Naveen-Kodakandla/publication/388755287\\_Securing\\_Cloud-Native\\_Infrastructure\\_with\\_Zero\\_Trust\\_Architecture/links/67a4d94a8311ce680c5868c0/Securing-Cloud-Native-Infrastructure-with-Zero-Trust-Architecture.pdf](https://www.researchgate.net/profile/Naveen-Kodakandla/publication/388755287_Securing_Cloud-Native_Infrastructure_with_Zero_Trust_Architecture/links/67a4d94a8311ce680c5868c0/Securing-Cloud-Native-Infrastructure-with-Zero-Trust-Architecture.pdf) [Accessed 5 June 2025].

Levine, A. and Tucker, B.A., 2023. Zero Trust Architecture: Risk Discussion. Digital Threats: Research and Practice, 4(1), Article 15. Available at: <https://doi.org/10.1145/3573892> [Accessed 11 June 2025].

Microsoft Docs, 2024. Azure AD Conditional Access policies. Microsoft Learn. Available at: <https://learn.microsoft.com/en-us/azure/active-directory/conditional-access/howto-conditional-access-policy-all-users> [Accessed 27 June 2025].

Microsoft Docs, 2024. Azure AD Identity Governance - Access Reviews. Microsoft Learn. Available at: <https://learn.microsoft.com/en-us/azure/active-directory/governance/access-reviews-overview> [Accessed 24 June 2025].

Microsoft Docs, 2024. Azure AD Identity Protection. Microsoft Learn. Available at: <https://learn.microsoft.com/en-us/azure/active-directory/identity-protection/overview-identity-protection> [Accessed 25 June 2025].

Microsoft Docs, 2024. Azure AD Identity Protection risk detections. Microsoft Learn. Available at: <https://learn.microsoft.com/en-us/azure/active-directory/identity-protection/howto-identity-protection-risk-policies> [Accessed 28 June 2025].

Microsoft Docs, 2024. Azure AD Privileged Identity Management. Microsoft Learn. Available at: <https://learn.microsoft.com/en-us/azure/active-directory/privileged-identity-management/pim-configure> [Accessed 26 June 2025].

Microsoft Docs, 2024. Integrate Azure AD logs with Azure Sentinel. Microsoft Learn. Available at: <https://learn.microsoft.com/en-us/azure/sentinel/connect-azure-active-directory> [Accessed 24 June 2025].

Microsoft Docs, 2024. Lifecycle workflows in Azure AD Identity Governance. Microsoft Learn. Available at: <https://learn.microsoft.com/en-us/azure/active-directory/governance/lifecycle-workflows-overview> [Accessed 26 June 2025].

Microsoft Docs, 2024. Secure access to Azure resources with Azure AD. Microsoft Learn. Available at: <https://learn.microsoft.com/en-us/azure/role-based-access-control/overview> [Accessed 29 June 2025].

Microsoft Docs, 2024. Zero Trust identity and device access policies. Microsoft Learn. Available at: <https://learn.microsoft.com/en-us/security/zero-trust/deploy/identity-device-access-policies> [Accessed 30 June 2025].

Microsoft Learn, 2024. Manage API access with Azure AD. Microsoft Learn. Available at: <https://learn.microsoft.com/en-us/azure/active-directory/develop/v2-permissions-and-consent> [Accessed 29 June 2025].

Microsoft Learn, 2024. Multi-Factor Authentication. Microsoft Learn. Available at: <https://learn.microsoft.com/en-us/azure/active-directory/authentication/concept-mfa-howitworks> [Accessed 27 June 2025].

Microsoft Learn, 2024. What is Conditional Access? Microsoft Learn. Available at: <https://learn.microsoft.com/en-us/azure/active-directory/conditional-access/overview> [Accessed 25 June 2025].

Michael, J.B., Dinolt, G.C., Cohen, F.B. and Wijesekera, D., 2022. Can You Trust Zero Trust? IEEE Computer, 55(8), pp.103-105. Available at: <https://ieeexplore.ieee.org/document/9847325> [Accessed 12 June 2025].

Rashid, A., Chivers, H., Danezis, G., Hankin, C., Martin, A. and Sasse, M.A., eds., 2021. The Cyber Security Body of Knowledge (CyBOK), Version 1.1. University of Bristol. Available at: [https://www.cybok.org/knowledgebase1\\_1/](https://www.cybok.org/knowledgebase1_1/) [Accessed 03 June 2025].

Rose, S., Borchert, O., Mitchell, S. and Connelly, S., 2020. Zero Trust Architecture. NIST Special Publication 800-207. Available at: <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-207.pdf> [Accessed 7 June 2025].

Shore, M., Zeadally, S. and Keshariya, A., 2021. Zero trust: The what, how, why, and when. IEEE Communications Magazine. Available at: <https://ieeexplore.ieee.org/abstract/document/9585170> [Accessed 6 June 2025].

Teerakanok, S., Uehara, T. and Inomata, A., 2021. Migrating to Zero Trust Architecture: Reviews and Challenges. Security and Communication Networks. Available at: <https://onlinelibrary.wiley.com/doi/pdf/10.1155/2021/9947347> [Accessed 13 June 2025].